

# Unifolio — Access Controls Policy

---

**Document owner:** Ahmed Al-Samak, CEO (security@unifolio.ca)

**Effective date:** 2026-05-13

**Last reviewed:** 2026-05-13

**Review cadence:** Annually, or upon material change to the technology stack, the workforce, or any incident touching access management.

This policy is a companion to **INFOSEC\_POLICY.md** and provides the access-control specifics Plaid's questionnaire requires. It applies to all Unifolio production systems, sensitive data, and the personnel and third parties who interact with them.

---

## 1. Scope and definitions

| Term                      | Meaning at Unifolio                                                                                                                                                                         |
|---------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Production systems</b> | Vercel hosting + serverless functions, Supabase Postgres + Auth + Storage + Edge Functions, Plaid item store, Microsoft 365 mailbox, Vercel DNS, GoDaddy registrar console, Finnhub API key |
| <b>Sensitive data</b>     | All Class A and Class B data per INFOSEC_POLICY.md §3 (user financial data + identity data)                                                                                                 |
| <b>Privileged role</b>    | Anyone able to alter production code, production data, or vendor account configuration                                                                                                      |
| <b>End user</b>           | A consumer of Unifolio (the natural person whose portfolio is being aggregated)                                                                                                             |
| <b>Workforce</b>          | Currently: the founder (Ahmed Al-Samak). Future contractors are added below as they are engaged                                                                                             |

---

## 2. Access principles

Unifolio enforces access on three principles:

1. **Least privilege.** Every identity (human, service account, or API client) holds only the permissions required to perform its assigned function. Browser clients receive only the Supabase `anon` key (public-readable subject to Row-Level Security). Service-role keys with full database access are restricted to server-side code paths and are stored only in Vercel's encrypted environment-variable store.

1. **Separation of duties (effective).** Production data, production hosting, source code, domain registration, and email each live with a distinct vendor (Supabase, Vercel, GitHub, GoDaddy, Microsoft). A compromise of any single vendor cannot, by itself, exfiltrate user data without crossing an additional vendor boundary.
1. **Verification before trust.** Every privileged action requires authentication that includes a second factor (see §4 below). End-user authentication requires verified email ownership before any account becomes active.

---

## 3. End-user access controls

---

### 3.1 Authentication

End users authenticate to Unifolio via **Supabase Auth** with email + password. Password requirements:

- Minimum 8 characters (Supabase default).
- Passwords are checked against the HavelBeenPwned breach corpus on signup and rejected if found.
- Passwords are stored as bcrypt hashes by Supabase Auth — Unifolio's application code never sees plaintext passwords at any point.

Email verification is **required** before any account is activated; the user cannot connect Plaid Link, import data, or persist any portfolio data prior to email confirmation.

### 3.2 Authorization

Every Postgres table containing Class A or Class B data has **Row-Level Security (RLS) policies enabled**. Each policy enforces `user_id = auth.uid()` so that even if a malicious browser client crafted a query, the database engine would refuse to return rows belonging to other users. RLS is enabled on:

- `accounts`, `holdings`, `transactions`, `realized_positions`, `import_batches`, `user_profiles`, `plaid_items`, `custom_assets`, and all related tables (see `supabase/schema.sql` for the canonical list — 22 RLS policies as of this writing).

### 3.3 Session management

- Sessions are managed by Supabase Auth's JWT-based access tokens with short expiry (1 hour) and refresh tokens (7 days).
- Tokens are stored in browser local storage; signed-out users have all local Unifolio data cleared (theme/currency caches excepted).
- The user can sign out from any device via Settings → Session → Sign Out.

Access Controls Policy · Unifolio Inc. · Generated 2026-05-13 · Canonical version: [github.com/2uay/unifolio](https://github.com/2uay/unifolio)

### 3.4 Multi-factor authentication for end users

TOTP-based MFA is **on the product roadmap (target: Q3 2026)** via Supabase Auth's built-in `auth.mfa.enroll()` flow. As of 2026-05-13, MFA is not deployed for end users. The compensating controls are: (a) mandatory email-verification gating before any sensitive action, (b) breach-list password rejection at signup, (c) the read-only nature of Unifolio (no money movement is possible through the app). See **CONSUMER\_MFA\_RATIONALE.md** for the formal compensating-controls statement.

## 4. Privileged / administrative access

### 4.1 Console access

Production console access (the ability to view or modify settings on a vendor's web UI) is restricted to the CEO. Each console is protected by:

| Vendor                           | Console URL                                 | MFA in use                                | Recovery factor                               |
|----------------------------------|---------------------------------------------|-------------------------------------------|-----------------------------------------------|
| Vercel                           | vercel.com/account                          | Authenticator-app TOTP                    | Backup codes stored in CEO password manager   |
| Supabase                         | supabase.com/dashboard                      | Authenticator-app TOTP                    | Backup codes stored in CEO password manager   |
| GitHub                           | github.com/settings                         | Authenticator-app TOTP + WebAuthn passkey | Recovery codes stored in CEO password manager |
| GoDaddy                          | account.godaddy.com                         | SMS / Authenticator-app TOTP              | SMS to verified mobile number                 |
| Microsoft 365 admin              | admin.microsoft.com                         | Authenticator-app TOTP                    | Backup phone number                           |
| Anthropic / OpenAI (dev tooling) | console.anthropic.com / platform.openai.com | TOTP                                      | Backup codes                                  |

The CEO maintains a current list of all console accounts and reviews them quarterly to confirm MFA remains enabled.

### 4.2 Code and deployment access

- **Source code repository** (GitHub: `2uay/unifolio`) is **public** for code transparency, but write access (push, branch protection bypass, secret access) is restricted to the CEO. All deploy keys are scoped read-only.
- **Production deploys** to Vercel are triggered exclusively by GitHub `main` branch pushes (auto-deploy) or manual `vercel --prod` from a credentialed CLI session. No deploy access is granted to anyone other than the CEO.
- Branch protection on `main` requires a successful build before merge. (Currently relaxed because the CEO is the sole committer; will tighten to "require PR review" upon onboarding the first additional engineer.)

### 4.3 Service / API credential management

- All vendor API keys (Supabase service-role, Plaid client+secret, Finnhub key, etc.) live exclusively in Vercel's encrypted environment-variable store (or equivalent server-side secret stores for Edge Functions).
- The browser-shipped JavaScript bundle contains only the Supabase **public anon key** (which is harmless because RLS policies enforce row isolation) and the Finnhub key (a public-data API where leaking the key only enables rate-limited public-quote queries).
- API keys are rotated:
  - **Annually**, as a baseline hygiene cycle.
  - **Immediately**, when a contractor with key access leaves.
  - **Immediately**, when a key is observed in any unintended location (logs, screenshots, Slack, chat tools, GitHub secret-scanning alerts).

### 4.4 Database direct access

- The Supabase Postgres direct-SQL editor is used only for incident investigation, schema migrations, or one-off operational queries.
- All routine reads and writes happen through application code with the public anon key + RLS.
- Direct-SQL sessions are logged by Supabase and reviewed by the CEO post-incident.

### 4.5 Provisioning and de-provisioning

#### Onboarding new workforce:

1. Document the scope of access required in writing (which vendors, which permissions, why).
2. Provision the minimum-viable account at each vendor (e.g., GitHub "Read" access + "Write" only on the specific repo branch they need).
3. Require MFA enrollment within 24 hours of account activation.
4. Require written acknowledgement of INFOSEC\_POLICY.md, ACCESS\_CONTROLS\_POLICY.md, and PRIVACY\_POLICY.md before access is granted.

**Offboarding workforce / contractor:**

- 1. Within 24 hours of departure or end of engagement: revoke vendor accounts (Vercel team member removal, Supabase project member removal, GitHub repo collaborator removal).
- 2. Rotate any API keys the departing person had access to.
- 3. Force a sign-out across all Supabase Auth sessions if the departing person had service-account or admin credentials.
- 4. Document the revocation in the project Git history (e.g., a commit removing them from a CODEOWNERS file).

**4.6 Periodic access review and audit**

- **Annually** the CEO reviews each vendor's user-access list and confirms only currently-authorized people have access.
- The review is documented in a dated row appended to **APPENDIX A** of this document (see below).
- For Plaid-related access specifically, the review confirms: (a) the Plaid environment (Sandbox / Development / Production) the keys point to, (b) the rotation date of the active client secret, (c) the count of active Plaid Items.
- Quarterly the CEO runs an automated query to detect any orphaned database rows (e.g., holdings with no matching auth user) and remediates within 7 days.

**5. Production-asset access matrix**

| Asset                                       | Production type | Authentication                        | Authorization                                          | Audit log retention       |
|---------------------------------------------|-----------------|---------------------------------------|--------------------------------------------------------|---------------------------|
| Supabase Postgres (Class A/B data)          | Database        | Supabase Auth JWT or service-role key | RLS per-user; service role bypass restricted to server | 7 days (Supabase default) |
| Supabase Storage ( <b>avatars</b> bucket)   | Object store    | Supabase Auth JWT                     | RLS bucket policies, public read for avatars only      | 7 days                    |
| Vercel hosting + DNS + serverless functions | Compute + DNS   | Vercel SSO + TOTP                     | Single-team account, CEO admin                         | 30 days                   |
| GitHub source repository                    | Source control  | GitHub login + TOTP/WebAuthn          | CEO admin; public read of code                         | 90 days                   |

| Asset                       | Production type | Authentication                    | Authorization                                    | Audit log retention                  |
|-----------------------------|-----------------|-----------------------------------|--------------------------------------------------|--------------------------------------|
| Plaid Items / access tokens | API-managed     | Vercel-stored Plaid client+secret | Server-side only; never exposed to browser       | Plaid retains per their SOC 2 policy |
| Microsoft 365 mailbox       | Email           | M365 sign-in + TOTP               | CEO mailbox; aliases dev@ + support@ + security@ | 90 days                              |
| Vercel + GoDaddy DNS        | DNS records     | Vercel/GoDaddy SSO + TOTP         | CEO admin                                        | Vendor-managed                       |

## 6. Logging and monitoring

- **Supabase** logs every API call, every auth event, and every database query (with retention per their plan).
- **Vercel** logs every deploy, every serverless invocation, and every edge-function execution.
- **GitHub** logs every push, every pull request, and every secret-scanning alert.
- **Plaid** logs every API call from the Unifolio backend (visible in the Plaid Dashboard).

The CEO reviews logs:

- **On every incident** triggered by a user report, vendor notification, or alert.
- **Monthly spot-check** of recent auth events for any anomaly (unfamiliar IPs, unexplained service-role usage).
- **Annually** as part of the access review.

Anomalies trigger the incident-response process documented in INFOSEC\_POLICY.md §8.

## 7. Physical access

Unifolio operates without a physical office. The single founder MacBook is hardened as follows:

- **FileVault disk encryption** enabled.
- **Password-protected screen lock** with automatic lock after 5 minutes of idle.
- **macOS automatic security updates** enabled.
- **Find My Mac** enabled for remote wipe in case of device loss.
- **No production credentials are stored on the device itself**; vendor logins are session-based and re-authenticate via the password manager.

- Backup of work data: the source code is in GitHub; production data is in Supabase. Loss of the device does not result in data loss.
- 

## 8. Third-party access

---

Unifolio does not grant any third party direct access to production systems. Vendor staff (Supabase, Vercel, Plaid, etc.) may have access to their own infrastructure under their published SOC 2 controls, but they cannot read Unifolio user data outside the documented vendor capabilities (e.g., Supabase staff can read the database for support, governed by their privacy commitments — Unifolio has executed Supabase's Data Processing Addendum which restricts this to incident response only).

External developers, security researchers, and consultants are granted access only via:

- Read-only access to the public GitHub repository (no credentials exchanged).
  - Time-bounded, scoped-down vendor accounts removed within 24 hours of engagement end (see §4.5 above).
- 

## 9. Policy enforcement and exceptions

---

This policy is enforced by the CEO. Exceptions to any control above must be:

- Documented in writing in this file under **APPENDIX B — Active Exceptions**.
- Time-bounded with an explicit expiration date.
- Reviewed at the next access-review cycle for either remediation or formal acceptance.

Material non-compliance with this policy is treated as a security incident and follows the incident-response process in INFOSEC\_POLICY.md §8.

---

## 10. Policy review

---

This policy is reviewed annually at minimum, and immediately after any access-related security incident. Changes are version-controlled in the public Unifolio repository ( [docs/ACCESS\\_CONTROLS\\_POLICY.md](#) ); the change log is the file's commit history.

---

## APPENDIX A — Access review log

---

| Date       | Reviewer       | Vendors reviewed                                        | Findings                                                                                    | Actions taken               |
|------------|----------------|---------------------------------------------------------|---------------------------------------------------------------------------------------------|-----------------------------|
| 2026-05-13 | Ahmed Al-Samak | Vercel, Supabase, GitHub, GoDaddy, Microsoft 365, Plaid | Initial policy adoption. All vendors scoped to single user (CEO). All MFA confirmed active. | None — baseline established |

(New rows are appended each annual review or post-incident.)

---

## APPENDIX B — Active exceptions

---

*None as of 2026-05-13.*

---

## Acknowledgement

---

— Ahmed Al-Samak, CEO, Unifolio Inc.  
2026-05-13